Risk-Adaptive Zero Trust for Securing Hybrid Workforces

Using Self-Supervised Anomaly Detection

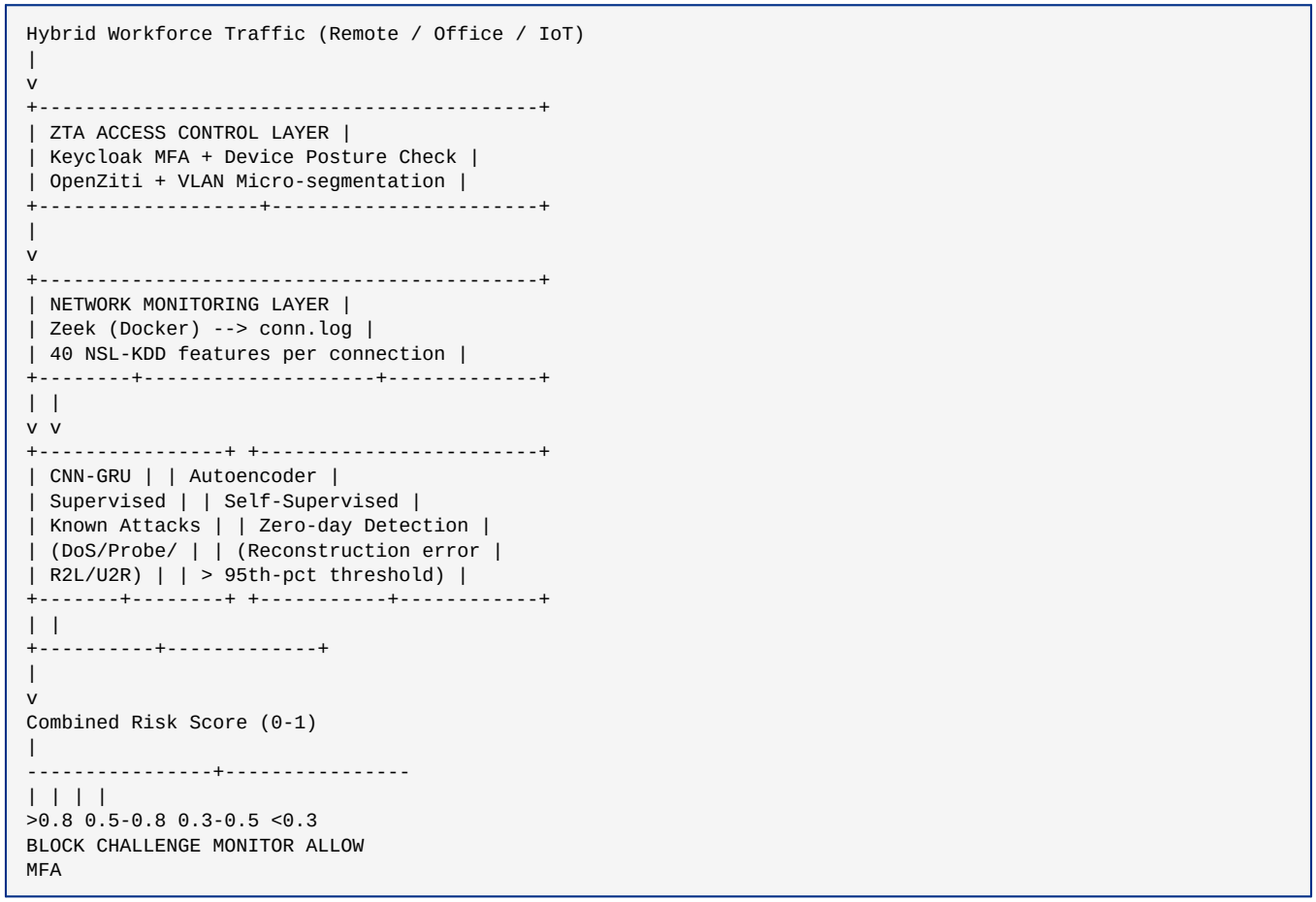
Okado Aaron Obbo	Reg No: **S24B23/015** | Student No: B29782	Date: **08 November 2026**

BSc Computer Science | Uganda Christian University

Abstract

Hybrid workforces expose enterprise networks to ransomware, lateral movement, insider attacks, and zero-day exploits that legacy VPN perimeters cannot block. This project designs and evaluates a risk-adaptive Zero Trust Architecture (ZTA) that integrates a dual-layer machine-learning pipeline: a supervised CNN-GRU for known-attack classification and a self-supervised autoencoder for zero-day anomaly detection trained on normal traffic only — requiring no attack labels. Both models feed a combined risk score (0–1) into the ZTA policy engine, which maps each network connection to an ALLOW, MONITOR, CHALLENGE_MFA, or BLOCK decision in real time. A controlled four-way comparison on the NSL-KDD benchmark dataset (22,543 test samples) shows that the ZTA+Autoencoder system achieves 0.8443 accuracy and 0.8482 F1, outperforming ZTA+CNN-GRU (0.7945 / 0.7886), ZTA-Only (0.7691 / 0.7677), and Legacy VPN (0.6664 / 0.6524), while being ~9× faster at inference (0.0656 ms/sample) and detecting zero-day attack classes the CNN-GRU was never trained on.

System Architecture



Key Results — Four-Way Comparison (NSL-KDD, 22,543 test samples)

System	Accuracy	F1 Score	FPR	Latency	Zero-Day
ZTA + Autoencoder	**0.8443**	**0.8482**	**0.0501**	**0.0656 ms**	✓
ZTA + CNN-GRU	0.7945	0.7886	0.0452	0.5889 ms	—

ZTA Only	0.7691	0.7677	N/A	N/A	—
Legacy VPN	0.6664	0.6524	N/A	N/A	—

Note: ZTA+Autoencoder achieves the highest accuracy and F1 and is ~9× faster than CNN-GRU at inference. R2L recall is 0.287 — those connections resemble normal traffic to the autoencoder (documented limitation). CNN-GRU achieves the lowest FPR (0.0452).

Research Contributions

- **Dual-layer ML pipeline:** Novel combination of a supervised CNN-GRU (Conv1D 64→128→256 + GRU 128→64, ~327K params) and a self-supervised autoencoder (Encoder 40→128→64→16, Decoder 16→64→128→40) into a single unified risk scoring system. Neither model alone achieves both known-attack classification and zero-day detection.
- **Self-supervised zero-day detection:** The autoencoder is trained on normal traffic only (67,343 samples, no attack labels). It achieves 0.8443 accuracy by measuring reconstruction error against a 95th-percentile threshold. Mean reconstruction error for attacks is ~19× higher than for normal traffic. Zero-day recall: DoS=0.911, Probe=0.882, U2R=0.687.
- **Flask REST API:** Production-ready risk-scoring API with /predict, /predict/batch, /health, and /model/info endpoints. Loads both models at startup, computes the combined risk score, and enforces ZTA policy (ALLOW / MONITOR / CHALLENGE_MFA / BLOCK) per connection in real time.
- **Four-way evaluation framework:** Rigorous controlled comparison of Legacy VPN, ZTA-Only, ZTA+CNN-GRU, and ZTA+Autoencoder on the same 22,543-sample NSL-KDD test set with identical metrics (Accuracy, F1, FPR, Latency, Zero-Day capability). Results are honest — weaknesses are reported alongside strengths.

Limitations

- **R2L recall: 0.287.** Remote-to-Local attacks reconstruct like normal traffic in the autoencoder, producing reconstruction errors below the 95th-percentile threshold. Their connection-level features (duration, byte counts, flag patterns) do not deviate significantly from benign traffic, making them the hardest class for reconstruction-based detection.
- **No live network deployment.** The system is evaluated on the NSL-KDD static benchmark dataset and a GNS3-simulated hybrid network. Performance on live enterprise traffic — with encrypted connections, adversarial evasion, and concept drift — has not been validated.
- **Threshold is static.** The 95th-percentile anomaly threshold is computed once at training time. It does not adapt online to shifts in normal traffic behaviour or seasonal drift.

Future Work

- **Adversarial robustness:** Evaluate the system against adversarial examples crafted to evade the autoencoder — e.g., minimal-perturbation DoS packets designed to reconstruct within the normal error range.
- **Federated learning for privacy:** Extend the autoencoder to a federated training scheme so distributed enterprise nodes can contribute to the normal-traffic model without sharing raw connection data.
- **Online / incremental learning:** Replace the static threshold with an adaptive anomaly detector that updates its normal-traffic distribution continuously, handling concept drift and evolving attack patterns without periodic full retraining.

References

[1] Gambo & Almulhem (2026). Zero Trust Architecture: A Systematic Literature Review. *Journal of Network and Systems Management*, 34(1).

[2] Zohaib et al. (2024). Zero Trust VPN (ZT-VPN). *Information*, 15(11).

[3] Bakhshi & Ghita (2021). Anomaly Detection in Encrypted Internet Traffic Using Hybrid Deep Learning. *Security and Communication Networks*.

[4] Kim et al. (2024). Exploring Effective Zero Trust Architecture for Defense Cybersecurity. *KSII Transactions on Internet and Information Systems*, 18(7).

[5] Abdelhady et al. (2026). Hybrid ML Anomaly Detection and Lightweight ZTA for LoRaWAN Networks. *IEEE Access*, 14.

[6] Tian et al. (2024). S4: Self-Supervised Learning with Sparse-Dense Sampling. *Knowledge-Based Systems*.

[7] Dhumal et al. (2025). ZTA for Ransomware Defense in Virtualized Environments. *IEEE/ACM BigData*.

Okado Aaron Obbo | Reg No: S24B23/015 | Student No: B29782 | BSc Computer Science | Uganda Christian University | github.com/asdcaaron/zta-ml-framework